SQLVault Gateway

# Note de déploiement DSI / RSSI

Faire de SQLVault Gateway le seul chemin d'accès aux bases : comptes, réseau, postes, audit et plan de bascule.

Pour la DSI, le RSSI, les DBA et les équipes réseau et postes de travail

Version : octobre 2026

DEF TECH 2.0 · sqlvaultgateway@gmail.com

# Table des matières

**Objectif et principe** ..... **2**

**Comptes des bases** ..... **2**

- Oracle ..... 2
- SQL Server ..... 3
- MySQL et MariaDB ..... 3
- PostgreSQL ..... 3

**Réseau** ..... **3**

**Postes de travail** ..... **4**

**Audit natif des bases** ..... **4**

- Oracle (audit unifié) ..... 4
- SQL Server (SQL Server Audit) ..... 4
- MySQL et MariaDB ..... 5
- PostgreSQL ..... 5

**Accès d'urgence et évolutions de structure** ..... **5**

- Accès d'urgence des DBA ..... 5
- Évolutions de structure (DDL) ..... 5

**Plan de bascule** ..... **6**

**Contrôles, indicateurs et responsabilités** ..... **6**

# Objectif et principe

**SQLVault Gateway doit devenir le seul chemin d'accès aux bases de données de la banque.** Les outils installés sur les postes (SQL Developer, DBeaver, DataGrip, Toad, SSMS, Excel/ODBC) seront interdits. L'éditeur de SQLVault Gateway reprend leurs fonctions du quotidien, et chaque requête y est analysée, masquée, validée si elle modifie des données, puis inscrite dans un journal d'audit signé.

SQLVault Gateway ne contrôle toutefois que ce qui passe par lui. L'interdiction ne tient que si la banque ferme les autres chemins, sur quatre plans :

| Plan | Mesure | Responsable |
|---|---|---|
| Comptes des bases | Seul le compte technique de SQLVault Gateway accède aux données ; les comptes personnels et partagés sont supprimés ou bloqués | DBA |
| Réseau | Les ports des bases ne sont ouverts qu'au serveur SQLVault Gateway | Équipe réseau |
| Postes de travail | Les clients SQL et les connexions ODBC directes sont bloqués | Équipe postes de travail |
| Audit natif | Toute connexion qui ne vient pas de SQLVault Gateway est détectée et alertée | DBA et RSSI |

Deux exceptions encadrées subsistent : l'accès d'urgence des DBA et les évolutions de structure (création de tables, migrations), que SQLVault Gateway refuse par conception.

**Socle technique.** Le moteur de SQLVault Gateway est écrit en Go, le langage de Docker, Kubernetes et Terraform. Il est livré en un seul programme compilé, sans machine Java ni serveur d'application, dans une image Docker légère qui tourne en lecture seule et sans privilèges. Il y a donc moins de composants à surveiller et à mettre à jour, et le langage écarte les failles mémoire courantes en C.

# Comptes des bases

**Les personnes n'ont plus de compte sur les bases : seul SQLVault Gateway s'y connecte, avec un compte technique à moindre privilège.** Les comptes des applications métier ne sont pas concernés.

- **Deux connexions par base**, déclarées dans SQLVault Gateway : une en *lecture seule* (droit `SELECT` uniquement), une en *écriture* pour les modifications validées (droits `INSERT`, `UPDATE`, `DELETE` limités aux tables concernées). Jamais de droit de structure (`CREATE`, `ALTER`, `DROP`), jamais de rôle d'administration.
- **Mot de passe** : généré, long, connu seulement de SQLVault Gateway (stocké chiffré AES-256-GCM), renouvelé selon la politique de la banque.
- **Comptes personnels et partagés** : verrouillés puis supprimés après la période de coexistence.

## Oracle

```
CREATE USER sqlvault_lecture IDENTIFIED BY "<mot de passe>";
GRANT CREATE SESSION TO sqlvault_lecture;
GRANT SELECT ON banque.clients TO sqlvault_lecture;   -- table par table, ou via un rôle dédié
-- Connexion d'écriture : même principe, avec INSERT, UPDATE, DELETE sur les tables concernées
ALTER USER jdiop ACCOUNT LOCK;                          -- chaque compte personnel
```

### SQL Server

```
CREATE LOGIN sqlvault_lecture WITH PASSWORD = '<mot de passe>', CHECK_POLICY = ON;
USE banque;
CREATE USER sqlvault_lecture FOR LOGIN sqlvault_lecture;
ALTER ROLE db_datareader ADD MEMBER sqlvault_lecture;
GRANT SHOWPLAN TO sqlvault_lecture;                    -- bouton « Plan » de l'éditeur
ALTER LOGIN [BANQUE\jdiop] DISABLE;                    -- chaque compte ou groupe Windows person
nel
```

### MySQL et MariaDB

```
CREATE USER 'sqlvault_lecture'@'<IP du serveur SQLVault Gateway>' IDENTIFIED BY '<mot de passe>';
GRANT SELECT ON banque.* TO 'sqlvault_lecture'@'<IP du serveur SQLVault Gateway>';
ALTER USER 'jdiop'@'%' ACCOUNT LOCK;                   -- chaque compte personnel
```

Le compte n'est accepté que depuis l'adresse du serveur SQLVault Gateway : même volé, son mot de passe ne sert à rien ailleurs.

### PostgreSQL

```
CREATE ROLE sqlvault_lecture LOGIN PASSWORD '<mot de passe>';
GRANT CONNECT ON DATABASE banque TO sqlvault_lecture;
GRANT USAGE ON SCHEMA public TO sqlvault_lecture;
GRANT SELECT ON ALL TABLES IN SCHEMA public TO sqlvault_lecture;
ALTER DEFAULT PRIVILEGES IN SCHEMA public GRANT SELECT ON TABLES TO sqlvault_lecture;
ALTER ROLE jdiop NOLOGIN;                              -- chaque compte personnel
```

Dans `pg_hba.conf`, n'autoriser ce compte que depuis le serveur SQLVault Gateway (`host banque sqlvault_lecture <IP>/32 scram-sha-256`) et refuser les autres connexions humaines.

## Réseau

**Un poste de travail ne doit plus pouvoir joindre une base : seuls le serveur SQLVault Gateway et les serveurs applicatifs y ont accès.** Les postes accèdent à SQLVault Gateway en HTTPS, par le navigateur.

| Source | Destination | Port | Décision |
|---|---|---|---|
| Postes des utilisateurs | Serveur SQLVault Gateway | 443 (HTTPS) | Autorisé |
| Serveur SQLVault Gateway | Bases Oracle | 1521 | Autorisé |
| Serveur SQLVault Gateway | Bases SQL Server | 1433 | Autorisé |
| Serveur SQLVault Gateway | Bases MySQL / MariaDB | 3306 | Autorisé |
| Serveur SQLVault Gateway | Bases PostgreSQL | 5432 | Autorisé |
| Serveur SQLVault Gateway | Relais de messagerie | 25 ou 587 | Autorisé (notifications et rapports) |
| Serveurs applicatifs | Bases | Ports ci-dessus | Inchangé |
| Bastion d'administration (accès d'urgence) | Bases | Ports ci-dessus | Autorisé, sessions enregistrées |
| Postes des utilisateurs, VPN, Wi-Fi | Bases | 1521, 1433, 3306, 5432 | **Refusé et journalisé** |

Les tentatives refusées sont remontées au SOC ou à l'outil de supervision de la sécurité : elles signalent un poste qui essaie encore un accès direct.

**Envoi de rapports aux clients (avis de débit et de crédit, relevés).** Désactivé par défaut : les rapports ne partent qu'aux domaines e-mail de la banque (`SQLGUARD_REPORT_DOMAINS`). L'envoi aux clients s'active explicitement (`SQLGUARD_REPORT_ALLOW_EXTERNAL=true`, nom de la banque dans `SQLGUARD_ORGANIZATION_NAME`) ; chaque planning qui sort de la banque est alors validé par un approbateur, après une simulation qui montre les destinataires, adresses masquées. Côté messagerie : le relais doit accepter l'envoi vers l'extérieur pour le compte de SQLVault Gateway, avec l'adresse d'expédition couverte par le SPF et la signature DKIM du domaine de la banque, sans quoi les avis finissent en courrier indésirable. Plafond par envoi : `SQLGUARD_REPORT_BURST_MAX` (500 clients par défaut).

# Postes de travail

**Le blocage réseau suffit à rendre les clients SQL inutiles ; le blocage des postes évite les contournements et les demandes d'exception.**

- **Interdire l'installation et l'exécution** des clients SQL par stratégie de groupe (AppLocker ou Windows Defender Application Control) : SQL Developer, SQL*Plus, Toad, SSMS, Azure Data Studio, DBeaver, DataGrip, HeidiSQL, MySQL Workbench, pgAdmin, psql.
- **Supprimer les sources de données ODBC et OLE DB** pointant vers les bases, et bloquer les connexions directes depuis Excel et Power BI Desktop (Power Query). Les besoins de tableaux récurrents passent par les rapports planifiés de SQLVault Gateway, envoyés en Excel.
- **Retirer les droits d'administrateur local** aux utilisateurs, sans quoi les deux mesures précédentes se contournent.
- **Communiquer avant la coupure** : date, raison, démonstration de l'éditeur SQLVault Gateway, et contact en cas de besoin non couvert.

# Audit natif des bases

**Chaque base enregistre ses connexions ; toute session qui ne vient ni de SQLVault Gateway ni d'une application connue déclenche une alerte au RSSI.** C'est la seule façon de repérer un contournement : un compte oublié, un accès depuis le bastion hors procédure, un pare-feu mal réglé.

**Règle d'alerte à configurer dans l'outil de supervision (SIEM)** : alerte haute si le compte n'est pas un compte `sqlvault_*` ou un compte applicatif déclaré, ou si l'adresse source n'est pas celle du serveur SQLVault Gateway ou d'un serveur applicatif.

## Oracle (audit unifié)

```
CREATE AUDIT POLICY sg_connexions ACTIONS LOGON;
AUDIT POLICY sg_connexions;
-- Contrôle : SELECT event_timestamp, dbusername, userhost FROM unified_audit_trail
--            WHERE action_name = 'LOGON' AND dbusername NOT LIKE 'SQLVAULT%';
```

## SQL Server (SQL Server Audit)

```
CREATE SERVER AUDIT sg_audit TO FILE (FILEPATH = 'D:\Audit\');
CREATE SERVER AUDIT SPECIFICATION sg_connexions FOR SERVER AUDIT sg_audit
  ADD (SUCCESSFUL_LOGIN_GROUP), ADD (FAILED_LOGIN_GROUP) WITH (STATE = ON);
ALTER SERVER AUDIT sg_audit WITH (STATE = ON);
```

### MySQL et MariaDB

- MariaDB : `INSTALL SONAME 'server_audit';` puis `SET GLOBAL server_audit_events = 'CONNECT'; SET GLOBAL server_audit_logging = ON;`
- MySQL Enterprise : extension `audit_log`. MySQL Community : extension d'audit de Percona, ou, à défaut, les refus journalisés par le pare-feu.

### PostgreSQL

Dans `postgresql.conf` : `log_connections = on` et `log_disconnections = on` ; l'extension `pgaudit` complète si la banque veut tracer les ordres exécutés hors SQLVault Gateway.

Les journaux natifs sont envoyés au SIEM et conservés selon la même durée que le journal d'audit de SQLVault Gateway.

## Accès d'urgence et évolutions de structure

**SQLVault Gateway refuse volontairement l'administration des bases et tout DDL destructeur ; l'accès d'urgence et les migrations passent par des circuits dédiés, tracés, et jamais par un client SQL sur un poste.**

### Accès d'urgence des DBA

- Comptes d'administration nominatifs, gardés dans un **coffre-fort à mots de passe** (gestion des accès privilégiés), sortis pour une intervention précise et renouvelés après usage.
- Connexion uniquement depuis le **bastion d'administration**, avec enregistrement de la session.
- Chaque sortie de compte est liée à un ticket d'incident et validée par un second responsable.
- Revue mensuelle par le RSSI : chaque connexion d'urgence vue dans l'audit natif doit correspondre à un ticket.

### Évolutions de structure (DDL)

- Migrations applicatives et vues : livrées sous forme de **scripts versionnés**, revus, puis déployés par la chaîne de mise en production avec un compte technique dédié.
- Optimisations courantes (index, table de travail, ajout de colonne, statistiques) : possibles par SQLVault Gateway, **sur les seules bases où la banque l'autorise**, avec justification et double validation. Le compte de service reçoit alors les droits nécessaires (en MySQL : CREATE, ALTER, INDEX), jamais DROP ni GRANT. Si la table est occupée, le changement est abandonné au lieu de bloquer la production.
- Les corrections de données ponctuelles passent, elles, par SQLVault Gateway : demande justifiée, double validation, exécution tracée.
- Procédures stockées métier : ajoutées à la liste blanche de la connexion par l'Administrateur technique ; leur appel suit la double validation.

# Plan de bascule

**La bascule se fait en quatre phases ; on ne passe à la suivante que lorsque la condition affichée entre les deux est remplie.** Les durées dépendent du nombre d'équipes et de bases : elles sont à fixer avec la DSI.

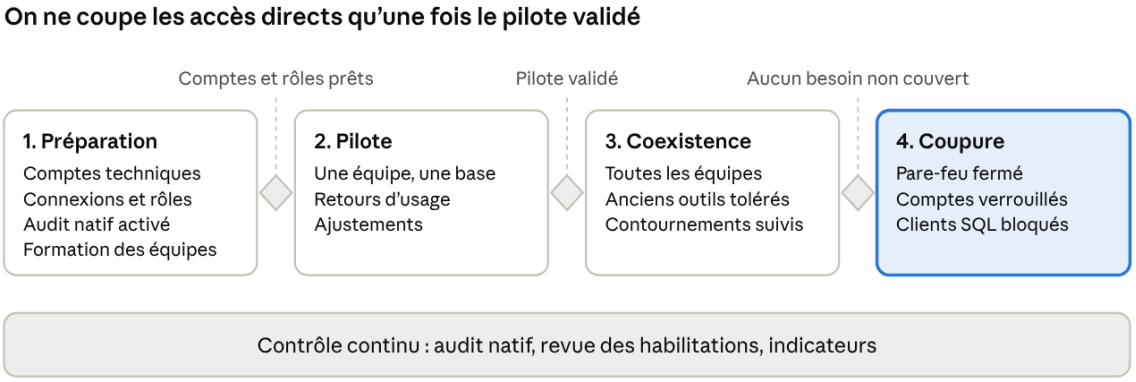



*Figure 1 · Plan de bascule : 4 phases, 3 conditions de passage*

Pendant la coexistence, l'audit natif montre qui se connecte encore en direct : ces personnes sont accompagnées avant la coupure, et chaque besoin non couvert est traité (rapport planifié, requête partagée, droit manquant).

# Contrôles, indicateurs et responsabilités

**Le dispositif est tenu tant que ces contrôles restent au vert ; ils se lisent dans SQLVault Gateway et dans le SIEM.**

| Indicateur | Cible | Source | Fréquence |
|---|---|---|---|
| Connexions humaines aux bases hors SQLVault Gateway et hors accès d'urgence | 0 | Audit natif, SIEM | En continu |
| Accès d'urgence sans ticket associé | 0 | Coffre-fort, audit natif | Mensuelle |
| Flux refusés des postes vers les ports des bases | En baisse jusqu'à 0 | Pare-feu | Hebdomadaire |
| Intégrité du journal d'audit SQLVault Gateway | Intact | SQLVault Gateway, « Vérifier l'intégrité » | Mensuelle |
| Revue des habilitations (comptes, rôles, droits) | Faite et signée | SQLVault Gateway, matrice Excel | Trimestrielle |
| Comptes sans connexion depuis 90 jours | Désactivés | SQLVault Gateway, matrice Excel | Trimestrielle |
| Alertes de sécurité SQLVault Gateway non traitées | 0 au-delà de 48 h | SQLVault Gateway, écran Alertes | Quotidienne |

| Activité | DSI | RSSI | DBA | Réseau | Postes |
|---|---|---|---|---|---|
| Comptes techniques et retrait des comptes personnels | Valide | Contrôle | Réalise | | |
| Matrice de flux du pare-feu | Valide | Contrôle | | Réalise | |
| Blocage des clients SQL et de l'ODBC | Valide | Contrôle | | | Réalise |
| Audit natif et règle d'alerte | | Décide | Réalise | | |
| Accès d'urgence (coffre-fort, bastion) | Valide | Contrôle | Réalise | | |
| Revue des habilitations SQLVault Gateway | | Contrôle | | | |

La revue des habilitations est conduite par le Super administrateur de SQLVault Gateway avec les responsables métier, à partir de la matrice exportée depuis l'écran « Rôles et droits ».

**Départ ou changement de poste d'un collaborateur.** Son compte SQLVault Gateway est désactivé le jour même : ses sessions sont fermées et ses rapports planifiés suspendus, puisqu'ils s'exécutent avec ses droits. Le Super administrateur transfère ensuite chaque rapport encore utile à un collègue (bouton « Transférer ») : plannings et destinataires sont conservés, le rapport s'exécute avec les droits du nouveau responsable et repart après la validation d'un approbateur. Les rapports devenus inutiles sont supprimés. Ces opérations sont inscrites au journal et vérifiées lors de la revue des habilitations.